Attacks on Hashing Algorithms and Message Authentication Codes

- Brute force
- Cryptanalysis

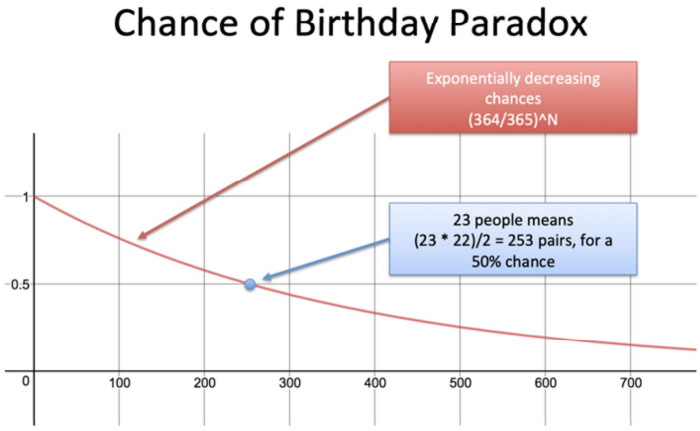
© 2018 Al-Nafi. All Rights Reserved.

Typically, attacks against hashing functions takes the form of finding collisions. There are two primary ways to attack hash functions:

- Brute force
- Cryptanalysis

Over the past number of years, extensive research has been done on attacks on various hashing algorithms, such as MD-5 and SHA-1. Both algorithms are susceptible to cryptographic attacks. A brute force attack relies on finding a weakness in the hashing algorithm that would allow an attacker to reconstruct the original message from the hash value (defeat the one-way property of a hash function), find another message with the same hash value, or find any pair of messages with the same hash value (called collision resistance).

The Birthday Paradox/Birthday Attack



© 2018 Al-Nafi. All Rights Reserved.

The Birthday Paradox/Birthday Attack
The birthday paradox is an interesting and surprising mathematical condition that describes the ease of finding two people with the same birthday (month and day) from a group of people. If one considers that there are 365 possible birthdays (not including leap years and assuming that birthdays are spread evenly across all possible dates), then one would expect to need to have roughly 183 people together to have a 50 percent
probability that two of those people share the same birthday.

But if you work it out mathematically, once there are more than 23 people together in a room, there is a greater than 50 percent probability that two of them share the same birthday. The reason that this is mathematically correct is that if you consider that in a
group of 23 people, there are 253 different pairings described by the formula: ($n(n-1)/2$). The probability increases to the point where once 100 people are together, the chance of two of them having the same birthday is actually greater than 99.99 percent.
This is referred to as the birthday paradox.

So why is this discussion about birthdays and the birthday paradox important while discussing attacks against hashing algorithms?

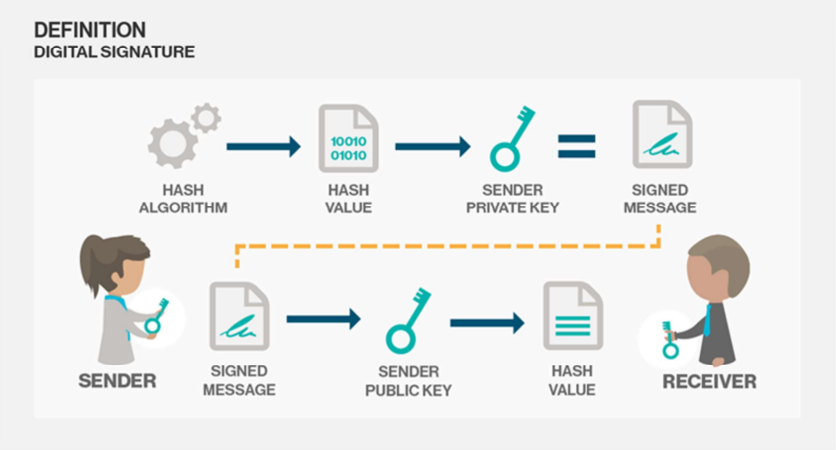
The answer is that the likelihood of finding a collision for two messages and their hash values may be a lot easier than may have been believed, just in the same way as the birthday paradox. The mathematics behind this would be very similar to the statistics of
finding two people with the same birthday. As we have seen, a most important consideration for evaluating the strength of a hashing algorithm must be its resistance to collisions. The probability of finding a collision for a 160-bit hash can be estimated at either 2 raised to the power of 160 or 2 raised to the power of 160/2, depending on the level of collision resistance needed. This approach is relevant because a hash is a representation of the message and not the message itself. As part of an attack, the
attacker does not want to find an identical message, the attacker wants to find out how to:

- Change the message contents to what the attacker wants it to read and still have the same digest value

- Cast some doubt on the authenticity of the original message by demonstrating that another message has the same value as the original

The hashing algorithm must be resistant to a birthday-type attack that would allow the attacker to feasibly accomplish his goals.

Digital Signatures – Non-repudiation

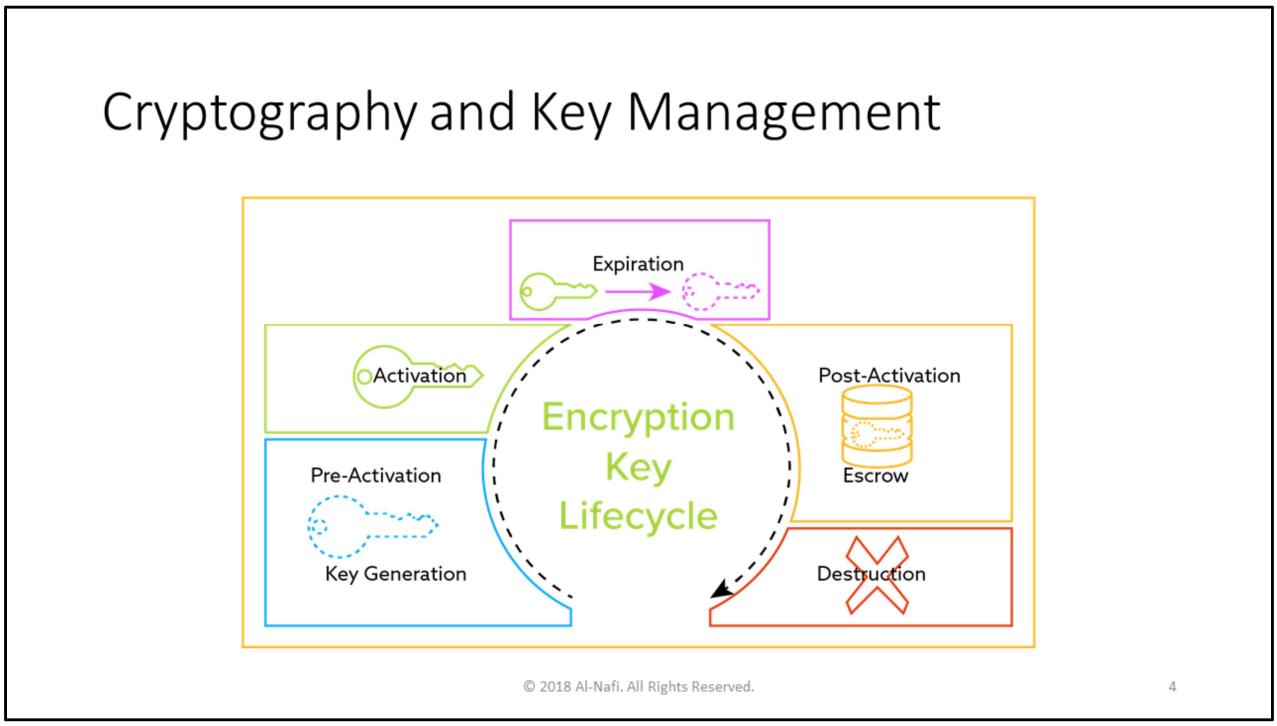


© 2018 Al-Nafi. All Rights Reserved.

Digital Signatures – Non-repudiation

Non-repudiation

Non-repudiation is the inability to deny. The word “repudiation” is defined as the ability to deny, so “non-repudiation” means the inability to deny. In cryptography, non-repudiation is a service that ensures the sender cannot deny a message was actually sent and the integrity of the message is intact, and the receiver cannot say that they’ve received a different message than the one that was actually received. Non-repudiation is achieved through digital signatures and PKI. The process is this: the message is signed using the sender’s private key. When the recipient receives the message, they may use the sender’s public key to validate the signature. While this proves the integrity of the message, it does not explicitly define the ownership of the original private key used to sign the message. For non-repudiation to be valid, a CA must have an association between the private key and the sender that proves the authenticity of the private key belonging to the entity having signed the message.



We will study this in further detail during our ISO 27001 and PCI DSS audit courses inshAllah.

Cryptographic Lifecycle

All cryptographic functions, systems and implementations have a useful life. In cryptography, the word "broken" typically means different things, depending on the application. A cryptographic function or implementation is considered broken or no longer effective when one of the following conditions is met:

For a hashing function:

- Collisions or hashes can be reliably reproduced in an economically feasible fashion without the original source.
- When an implementation of a hashing function allows a side channel attack. A side channel attack in cryptography is defined as targeting the weakness of the "implementation" of the algorithm and not the algorithm itself.

For an encryption system:

- A cipher is decoded without access to the key in an economically feasible fashion.

- When an implementation of an encryption system allows for the unauthorized disclosure of information in an economically feasible fashion.
- When a private key has been compromised in asymmetric key cryptography.

Algorithm/Protocol Governance

- Approved cryptographic algorithms and key sizes
- Transition plans for weakened or compromised algorithms and keys
- Procedures for the use of cryptographic systems in the organization and standards indicating what information and processes are subject to cryptographic requirements
- Key generation, escrow, and secure destruction
- Incident reporting surrounding the loss of keys or the compromise of cryptographic systems

© 2018 Al-Nafi. All Rights Reserved.

Issues Surrounding Cryptography

- The power of cryptography has been and is increasingly misused by those with criminal intentions and is subject to export and law enforcement requirements by countries and governments.

- Digital rights management (DRM) systems require a design and governance that can be used to both protect intellectual property and individual privacy while ensuring an individual's fair use of the intellectual property.

© 2018 Al-Nafi. All Rights Reserved.

International Export Controls

Cryptography is considered in most countries to be on par with munitions, a military tool, and may be managed through laws written to control the distribution of military equipment. Some countries do not allow any cryptographic tools to be used by their citizens, and others have laws that control the use of cryptography, usually based on key length and strength of algorithms.

© 2018 Al-Nafi. All Rights Reserved.

Cryptography is considered in most countries to be on par with munitions, a military tool, and may be managed through laws written to control the distribution of military equipment. Some countries do not allow any cryptographic tools to be used by their citizens, and others have laws that control the use of cryptography, usually based
on key length and strength of algorithms. This is because in cryptography, the key length is one of the most understandable methods of gauging the strength of a cryptosystem.

International export controls may be employed by governments to limit the shipment of products containing strong cryptography to countries that the government feels are trustworthy enough to use in a friendly way. Most countries' concern over their national security related to cryptography is established as specific technologies that would be detrimental to their national defense and, therefore, need to be controlled through export regulations. As a result of these export controls, many vendors market two versions of their products, one version that may have strong encryption and the other version that may have weaker encryption that is sold in other countries.

Key Management and Key Management Practices

- Key Recovery
- Dual Control and Split Knowledge
- Key Escrow
- Creation of Keys
  - ❑Automated key generation
  - ❑Truly random
  - ❑Asymmetric key length

© 2018 Al-Nafi. All Rights Reserved.

We will cover this in further detail during our ISO 27001 and PCI DSS courses inshAllah.